



Penetrationstest-Bericht

Mr Robot CTF – TryHackMe

Julian Ertle

Matr.Nr.: xxxxxx

19.01.2026

Inhaltsverzeichnis

1. Auftrag und Auftragsdurchführung	3
2. Management Summary	3
3. Tabellarische Darstellung der Feststellungen.....	4
4. Prüfungsergebnisse im Detail	5
4.1 Fehlkonfiguriertes SUID-Bit (Nmap)	5
4.2 Base64-kodierte Credentials	6
4.3 Wörterliste (fsociety.dic)	8
4.4 Schwache Passworthashes (MD5)	9
4.5 WordPress-Fehlermeldungen	11
4.6 Offenlegung via robots.txt	12
5. Risikobewertung	13

1. Auftrag und Auftragsdurchführung

Im Rahmen einer Sicherheitsüberprüfung wurde ein externer Penetrationstest auf das Zielsystem 10.82.164.217 durchgeführt. Bei dem untersuchten Host handelt es sich um die virtuelle Maschine "Mr. Robot CTF", bereitgestellt über die Lernplattform TryHackMe.

Methodik und Ansatz:

Der Test wurde als Black-Box-Ansatz simuliert. Dies bedeutet, dass dem Prüfer zu Beginn keinerlei Insider-Kenntnisse, Zugangsdaten oder Informationen über die interne Infrastruktur vorlagen. Ziel war es, die Perspektive eines externen Angreifers einzunehmen und die Widerstandsfähigkeit des Systems gegen reale Bedrohungen zu testen.

Zielsetzung (Capture The Flag):

Das Hauptziel war die Identifikation von Schwachstellen, um die drei im System versteckten Sicherheitsmarken (Flags) zu extrahieren:

- **Key 1:** Zugriff auf das öffentliche Web-Verzeichnis.
- **Key 2:** Lokaler Benutzerzugriff (Horizontal Privilege Escalation zum User robot).
- **Key 3:** Vollständige Systemübernahme (Vertical Privilege Escalation zu root).

Test-Scope:

- **Ziel-IP:** 10.82.164.217
- **Plattform:** TryHackMe (Vulnerable Lab Environment)
- **Standards:** Die Durchführung orientierte sich an den Richtlinien des OWASP und des BSI.

Untersuchungszeitraum:

Der Test wurde am 20.12.2025 durchgeführt. Die Ergebnisse basieren auf dem technischen Stand des Systems zu diesem Zeitpunkt. Alle identifizierten Schwachstellen wurden dokumentiert, um die notwendigen Härtingsmaßnahmen aufzuzeigen.

2. Management Summary

Zusammenfassend wurde im Rahmen des Penetrationstests auf die Mr. Robot Instanz festgestellt, dass das System erhebliche Sicherheitsmängel aufweist. Durch eine Verkettung von Informationslecks und Fehlkonfigurationen konnte die vollständige Kontrolle über den Server (Root-Zugriff) erlangt werden.

Die Analyse ergab insgesamt sechs Schwachstellen:

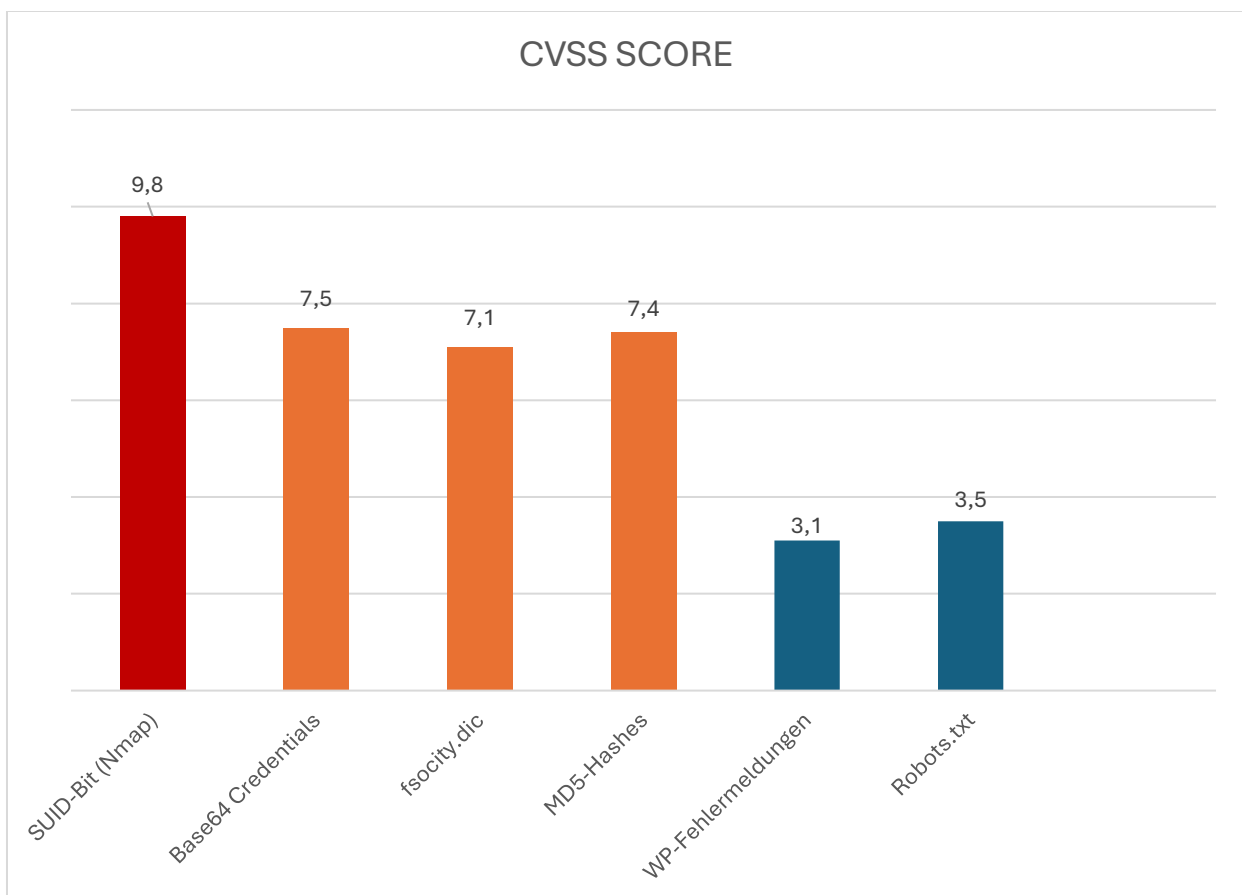
- **1 Kritische Schwachstelle:** Ein fehlerkonfiguriertes SUID-Bit bei Nmap erlaubte den direkten Aufstieg zum System-Administrator.
- **3 Hohe Schwachstellen:** Die Preisgabe der Wörterliste fscity.dic, ungeschützte Base64-Credentials und die Verwendung veralteter MD5-Hashes ermöglichten die Übernahme von Benutzerkonten.

- **2 Niedrige Schwachstellen:** Die Robots.txt sowie spezifische WordPress-Fehlermeldungen dienten als Wegweiser und lieferten wertvolle Informationen für die Angriffsplanung.

Fazit: Die Sicherheit des Systems ist zum aktuellen Zeitpunkt nicht gewährleistet. Ein Angreifer kann sich ohne Insider-Wissen schrittweise vom einfachen Web-Besucher zum Administrator hocharbeiten. Wir empfehlen eine sofortige Umsetzung der im Bericht genannten Härungsmaßnahmen, insbesondere den Entzug unnötiger Privilegien und die Absicherung sensibler Daten im Web-Verzeichnis.

3. Tabellarische Darstellung der Feststellungen

ID	Feststellung	CWE	Risikobewertung
4.1	Fehlkonfiguriertes SUID-Bit	CWE-269	Kritisch
4.2	Base64 Credentials	CWE-312	Hoch
4.3	Offenlegung fsociety.dic	CWE-200	Hoch
4.4	MD5-Hash (User robot)	CWE-916	Hoch
4.5	WP-Fehlermeldungen	CWE-209	Niedrig
4.6	Offenlegung via Robots.txt	CWE-548	Niedrig



4. Prüfungsergebnisse im Detail

4.1 Fehlkonfiguriertes SUID-Bit (Nmap)

Feststellung

Im Rahmen der Privilege-Escalation-Analyse wurde eine veraltete Version von Nmap (2.02) identifiziert, bei der das SUID-Bit gesetzt ist. Da der Besitzer der Datei der Benutzer root ist, wird das Programm bei Ausführung durch jeden beliebigen Nutzer mit Administratorrechten gestartet. Über den integrierten interaktiven Modus konnte eine Shell aufgerufen werden, die diese Privilegien vollständig erbt.

Betroffene Systeme

Systempfad	IP
/usr/local/bin/nmap	10.82.164.217

Nachweis

- **Befehl** (Identifikation der Datei): `find / -perm -u=s -type f 2>/dev/null`
- **Exploit**: `nmap --interactive` gefolgt von `!sh`
- **Ergebnis**: `whoami` liefert root.

```
robot@ip-10-82-142-214:~$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/mount
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/pkexec
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
robot@ip-10-82-142-214:~$
```

```
robot@ip-10-82-142-214:~$ /usr/local/bin/nmap --interactive
/usr/local/bin/nmap --interactive
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
root@ip-10-82-142-214:~# whoami
whoami
root
root@ip-10-82-142-214:~# ls /root/
ls /root/
firstboot_done  key-3-of-3.txt
root@ip-10-82-142-214:~# cat key-3-of-3.txt
cat key-3-of-3.txt
cat: key-3-of-3.txt: No such file or directory
```

Risikobewertung

- Kritisch (CVSS 9,8)
- CWE-269: Improper Privilege Management

Risiko

Das Risiko ist als existenziell einzustufen. Da ein Angreifer volle Root-Rechte erlangt, entfallen sämtliche Sicherheitsbarrieren des Betriebssystems. Dies ermöglicht:

- Vollständige Datenextraktion: Zugriff auf alle Dateien, Datenbanken und Passwörter im System
- Systemmanipulation: Installation von Backdoors (Persistent Access) oder Ransomware
- Lateral Movement: Nutzung des kompromittierten Servers als Brückenkopf, um tiefer in das interne Unternehmensnetzwerk einzudringen

Behebungsempfehlung

- Unverzüglicher Entzug des SUID-Bits für alle Tools, die keine Root-Rechte zur Ausführung benötigen
- Aktualisierung von Nmap auf eine Version, die keinen interaktiven Modus mehr unterstützt

4.2 Base64-kodierte Credentials

Feststellung

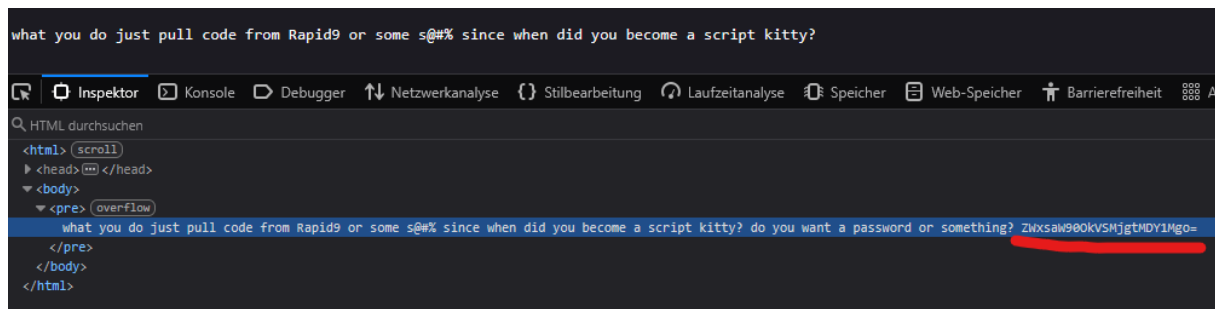
Im Rahmen der Verzeichnis-Analyse wurde die öffentlich zugängliche Datei /license identifiziert. Diese enthielt eine Zeichenfolge, die als Base64 kodiert war. Da Base64 ein rein technisches Format zur Datenübertragung und keine kryptografische Verschlüsselung darstellt, konnten die darin enthaltenen Informationen unmittelbar dekodiert werden. Die extrahierten Daten stellten sich als gültige Anmeldedaten für das WordPress-Backend heraus.

Betroffene Systeme

URL	IP
http://10.82.164.217/license	10.82.164.217 Port 80 (HTTP)

Nachweis

- **Fundstelle:** http://10.82.164.217/license
- **Kodierter String:** ZWxsaW900kVSMjgtMDY1Mgo=
- **Dekodierung:** Mittels Online-Tool oder Befehl `echo "[STRING]" | base64 -d`.
- **Ergebnis:** Offenlegung von Benutzernamen und Passwort im Klartext, dekodierter String: `elliottER28-0652`



```
what you do just pull code from Rapid9 or some s@#% since when did you become a script kitty?  
what you do just pull code from Rapid9 or some s@#% since when did you become a script kitty? do you want a password or something? ZnxsaW900kVSMjgtMDY1Mgo=  
do you want a password or something? ZnxsaW900kVSMjgtMDY1Mgo=
```

Risikobewertung

- **Hoch (CVSS 7,5)**
- **CWE-312:** Cleartext Storage of Sensitive Information

Risiko

Die Preisgabe von Zugangsdaten stellt ein hohes Risiko für die Vertraulichkeit dar. Ein Angreifer kann sich ohne technischen Aufwand Zugang zur Administrations-Oberfläche der Webanwendung verschaffen. Dies führt zu:

- **Account-Übernahme:** Unbefugte Anmeldung
- **Datenverlust:** Zugriff auf sensible Nutzerdaten innerhalb von WordPress
- **Defacement:** Manipulation der Website-Inhalte oder Einschleusen von Schadcode (Malvertising)

Behebungsempfehlung

- **Datenbereinigung:** Unverzügliche Löschung aller Dateien aus dem Web-Verzeichnis, die Anmeldedaten oder Konfigurationsdetails enthalten
- **Sichere Passwort-Policy:** Passwörter dürfen niemals im Dateisystem einer Webanwendung gelagert werden. Nutzen Sie stattdessen sichere Passwort-Manager oder verschlüsselte Umgebungsvariablen
- **Credential Rotation:** Da die Zugangsdaten öffentlich einsehbar waren, müssen diese umgehend global geändert werden

4.3 Wörterliste (fsociety.dic)

Feststellung

Im öffentlichen Web-Verzeichnis wurde die Datei fsociety.dic identifiziert. Dabei handelt es sich um ein umfangreiches Wörterbuch, das speziell für dieses System generierte Begriffe enthält. Da die Datei ohne jegliche Zugriffsbeschränkung im Web-Root hinterlegt war, konnte sie von externen Angreifern problemlos heruntergeladen werden.

Betroffene Systeme

URL	IP
http://10.82.164.217/fsociety.dic	10.82.164.217 Port 80 (HTTP)

Nachweis

- **Analyse:** Die Datei enthält tausende Begriffe, die Dubletten-bereinigt als perfekte Basis für einen Brute-Force-Angriff dienen
- **Anwendung:** Nutzung der Liste in Tools wie Hydra, um das WordPress-Login gezielt zu attackieren

Risikobewertung

- **Hoch (CVSS 7,1)**
- **CWE-200:** Exposure of Sensitive Information to an Unauthorized Actor

Risiko

Die Bereitstellung einer maßgeschneiderten Wörterliste stellt ein hohes Risiko dar, da sie die Effektivität von Passwort-Angriffen massiv steigert:

- **Effiziente Brute-Force-Angriffe:** Ein Angreifer muss nicht mehr raten, sondern nutzt die bereitgestellten Begriffe, was die Zeit zum Knacken von Accounts drastisch verkürzt
- **Gezielte Enumeration:** Die Liste gibt Rückschlüsse auf die Namenskonventionen und Themenbereiche des internen Systems, was weitere Angriffe erleichtert

Behebungsempfehlung

- **Dateihygiene:** Konsequente Entfernung aller Arbeitsdateien, Wörterlisten oder Backup-Archive aus dem öffentlichen Web-Verzeichnis.
- **Zugriffsschutz:** Falls solche Dateien serverseitig benötigt werden, müssen sie außerhalb des öffentlichen Verzeichnisses oder in passwortgeschützten Bereichen gelagert werden.

4.4 Schwache Passworthashes (MD5)

Feststellung

Nachdem durch eine Reverse-Shell Zugriff als Benutzer daemon erlangt wurde, konnte das Verzeichnis /home/robot eingesehen werden. Dort befand sich die Datei password.raw-md5, die den Passwort-Hash des Benutzers robot im Klartext enthielt. Die Analyse ergab, dass es sich um einen MD5-Hash handelt. Da MD5 keine modernen Schutzmechanismen wie "Salting" nutzt und das gewählte Passwort zudem schwach war, konnte der Hash über Online-Datenbanken (Rainbow Tables) unmittelbar entschlüsselt werden.

Betroffene Systeme

IP	Systempfad	Kompromittierter Benutzer
10.82.164.217	/home/robot/password.raw-md5	robot

Nachweis

- **Aktion:** Auslesen der Datei mittels cat.
- **Dekodierung:** Nutzung von Webdiensten wie CrackStation. Da das Passwort bereits von anderen Nutzern weltweit geknackt wurde, ist der Hash in diesen Datenbanken bereits hinterlegt und sofort auflösbar.

```
$ cd robot
$ ls
key-2-of-3.txt
password.raw-md5
$ cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
$
```

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

c3fcd3d76192e4007dfb496cca67e13b

Ich bin kein Roboter.

Die Nutzungsbedingungen für reCAPTCHA werden geändert. [Jetzt ansehen](#)

reCAPTCHA

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
c3fcd3d76192e4007dfb496cca67e13b	md5	abcdefghijklmnopqrstuvwxyz

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

Risikobewertung

- **Hoch (CVSS 7,4)**
- **CWE-916:** Use of Inherently Weak Hash

Risiko

Die Verwendung schwacher Hashes und unsicherer Passwörter führt zu einer schnellen horizontalen Privilegieneskalation. Ein Angreifer, der bereits Zugriff auf einen niedrig privilegierten Dienst-Account (wie daemon) hat, kann so innerhalb von Sekunden die Identität eines echten Systembenutzers (robot) annehmen und auf dessen private Daten zugreifen.

Behebungsempfehlung

- **Passwort-Policy:** Erzwingen von komplexen Passwörtern, die nicht in gängigen Wörterlisten oder Rainbow Tables vorkommen.
- **Modernes Hashing:** Umstellung auf bcrypt oder Argon2, um das Vorberechnen von Hash-Tabellen technisch unmöglich zu machen.
- **Dateiberechtigung:** Sensible Dateien mit Passwort-Hashes dürfen nicht für andere lokale Benutzer lesbar sein.

4.5 WordPress-Fehlermeldungen

Feststellung

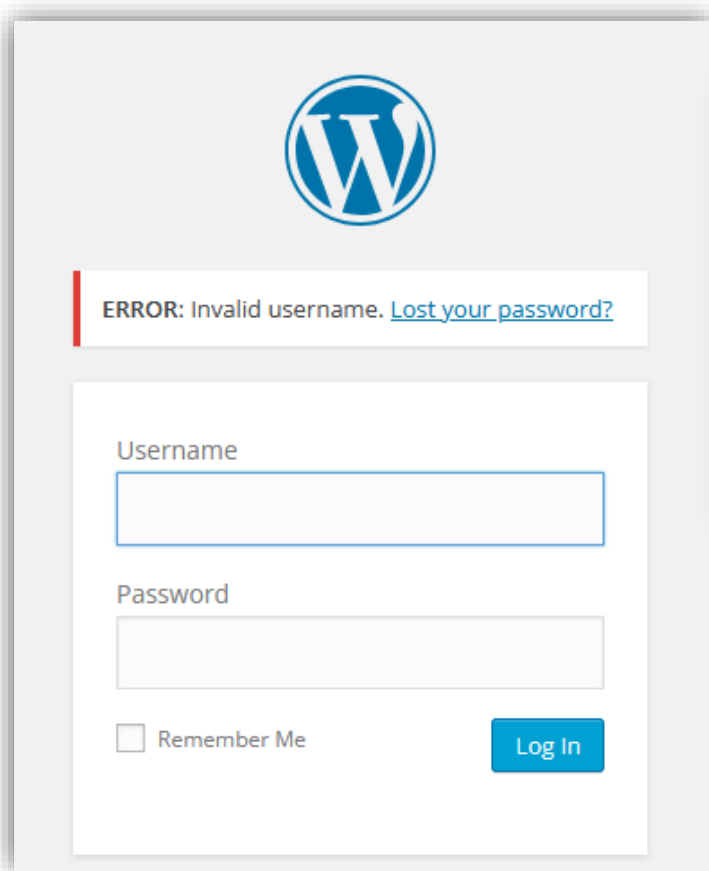
Bei der Analyse des WordPress-Login-Bereichs wurde festgestellt, dass die Anwendung detaillierte Rückmeldungen bei fehlgeschlagenen Anmeldeversuchen liefert. Das System unterscheidet explizit zwischen einem ungültigen Benutzernamen und einem falschen Passwort. Durch diese differenzierten Fehlermeldungen konnte die Existenz des Benutzers „elliot“ verifiziert werden.

Betroffene Systeme

URL	IP	Dienst
http://10.82.164.217/wp-login.php	10.82.164.217 Port: 80 (HTTP)	WordPress Login

Nachweis

- **Szenario A:** Eingabe eines unbekannten Nutzers -> Meldung: ERROR: Invalid username. [Lost your password?](#)
- **Szenario B:** Eingabe von „elliot“ -> Meldung: ERROR: The password you entered for the username elliot is incorrect. [Lost your password?](#)
- **Ergebnis:** Bestätigung des Benutzernamens „elliot“ als valides Angriffsziel.



The screenshot shows the WordPress login interface. At the top is the WordPress logo. Below it, a red error message states: "ERROR: Invalid username. [Lost your password?](#)". The login form contains two input fields: "Username" and "Password". Below the "Password" field is a checkbox labeled "Remember Me" and a blue "Log In" button.



The screenshot shows the WordPress login interface. At the top is the WordPress logo. Below it, a red error message states: "ERROR: The password you entered for the username elliot is incorrect. [Lost your password?](#)".

Risikobewertung

- **Niedrig (CVSS 3,1)**
- **CWE-209:** Generation of Error Message Containing Sensitive Information

Risiko

Die detaillierte Fehlerausgabe führt zur sogenannten User Enumeration. Dies stellt ein Risiko für die Vorbereitung von Angriffen dar:

- **Gezielte Angriffe:** Ein Angreifer muss keine Benutzernamen mehr raten (Brute-Force), sondern kann seine Ressourcen gezielt auf den verifizierten Account „elliot“ konzentrieren
- **Informationsgewinn:** Die Bestätigung von Usernames ist der erste notwendige Schritt für erfolgreiche Social-Engineering- oder Credential-Stuffing-Angriffe

Behebungsempfehlung

- **Generische Meldungen:** Konfiguration der Anwendung, sodass bei jedem Fehlversuch die identische, neutrale Meldung ausgegeben wird (z. B. „Ungültige Anmeldedaten“).
- **Login-Härtung:** Implementierung von Plugins, die User Enumeration unterbinden und die Anzahl der Anmeldeversuche pro IP-Adresse limitieren.

4.6 Offenlegung via robots.txt

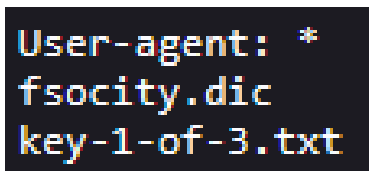
Feststellung

Während der Aufklärungsphase wurde die Datei robots.txt auf dem Zielsystem analysiert. Es wurde festgestellt, dass dort sensible Pfade und Dateien gelistet sind, die explizit von Suchmaschinen ausgeschlossen werden sollten. Diese Datei fungierte als „Schatzkarte“, da sie den Pfad zum ersten Key sowie zur kritischen Wörterliste fsociety.dic direkt preisgab.

Betroffene Systeme

URL	IP	Dienst
http://10.82.164.217/robots.txt	10.82.164.217 Port: 80 (HTTP)	Webserver-Konfigurationsdatei

Nachweis



```
User-agent: *  
fsociety.dic  
key-1-of-3.txt
```

- **Ergebnis:** Unmittelbare Identifikation von Dateien, die für den weiteren Angriffsverlauf (Brute-Force & Key-Collection) essenziell waren.

Risikobewertung

- **Niedrig (CVSS 3,5)**

- **CWE-548:** Exposure of Information Through Directory Listing

Risiko

Die robots.txt ist kein Sicherheitswerkzeug, sondern lediglich ein Hinweis für Web-Crawler. Die unsachgemäße Nutzung führt zu folgenden Risiken:

- **Informationsabfluss:** Angreifer finden gezielt versteckte Dateien oder Admin-Bereiche, ohne das System aufwendig scannen zu müssen.
- **Security through Obscurity:** Das bloße Verstecken von Pfaden bietet keinen echten Schutz, es weist Angreifern aktiv den Weg zu sensiblen Daten.

Behebungsempfehlung

- **Zugriffskontrollen:** Sensible Dateien sollten durch technische Maßnahmen (z. B. .htaccess, Authentifizierung oder Verzeichnisschutz) abgesichert werden.
- **Dateien verschieben:** Informationen, die nicht für die Öffentlichkeit bestimmt sind, sollten vollständig aus dem Web-Root entfernt werden.
- **Meta-Tags:** Nutzung von noindex-Tags im Header einzelner Seiten anstatt einer zentralen Liste in der robots.txt.

5. Risikobewertung

Die Sicherheitsüberprüfung der Mr. Robot Instanz zeigt ein kritisches Gesamtrisiko. Zwar sind einige Befunde für sich genommen nur als "Niedrig" eingestuft, doch in ihrer Kombination bilden sie eine lückenlose Angriffskette, die von der ersten Informationsbeschaffung bis zur vollständigen Kompromittierung des Servers führt.

5.1 Gesamtrisiko und Auswirkung

Das Risiko für den Betrieb wird als existenzbedrohend eingestuft. Einem externen Angreifer ohne Vorkenntnisse war es möglich, innerhalb kürzester Zeit folgende Ziele zu erreichen:

- **Identitätsdiebstahl:** Durch die Kombination aus robots.txt (4.6), der Wörterliste (4.3) und der User Enumeration (4.5) konnten gültige Benutzerkonten übernommen werden.
- **Vollständiger Datenzugriff:** Durch das Auslesen lokaler Dateien (4.4) wurden weitere Privilegien erlangt.
- **Root-Übernahme:** Die Fehlkonfiguration von Nmap (4.1) markiert den finalen Bruch der Systemsicherheit, wodurch der Angreifer volle Kontrolle über alle Daten, Dienste und Passwörter des Systems erhielt.

5.2 Strategische Empfehlungen

Um das Sicherheitsniveau nachhaltig zu steigern, sollten nicht nur die Einzelschwachstellen behoben werden, sondern folgende strategische Ansätze verfolgt werden:

1. **Härtung des Betriebssystems:** Regelmäßige Überprüfung von SUID-Berechtigungen und Deinstallation nicht benötigter Werkzeuge auf Produktivsystemen.
2. **Sichere Web-Konfiguration:** Striktes Verbot der Lagerung von Anmeldedaten (auch kodiert) oder Arbeitsdateien (.dic, .txt) im öffentlichen Web-Verzeichnis.

3. **Modernisierung der Kryptografie:** Übergang von MD5 zu sicheren Hashing-Verfahren wie BCrypt, um lokaler Privilegieneskalation vorzubeugen.